Enterprise Infrastructure Architecture

ICT Infrastructure Case Study – Week 2: Architectural Foundation

Case Study

Bas Smit

Fontys University of Applied Sciences

Fontys
University of Applied Sciences

Contents

1 Introduction **1**
1.1 Purpose of This Document . . . 1
1.2 Assumptions and Scope . . . 1

2 Enterprise Context **2**
2.1 Organisation Overview . . . 2
2.2 Locations . . . 2
2.3 Organisational Structure . . . 2
2.4 Core Business Processes . . . 2
2.5 Business Criticality and Risk Profile . . . 3
2.6 Key Stakeholders and Their Interests . . . 4
2.7 Customer Load and Capacity Assumptions . . . 4
2.8 Summary of Assumptions . . . 4

3 Architecture Method **5**
3.1 Overview . . . 5
3.2 TOGAF and the Architecture Development Method . . . 5
3.3 ArchiMate as Modelling Language . . . 6
3.4 How the Method Influenced This Work . . . 6

4 Enterprise Infrastructure Architecture **7**
4.1 Architectural Principles . . . 7
4.2 Network Segmentation . . . 7
4.3 Site: Eindhoven (Primary) . . . 7
4.3.1 Perimeter and DMZ . . . 8
4.3.2 Application Server Clusters . . . 8
4.3.3 Message Broker: RabbitMQ . . . 8
4.3.4 Backend: Database Layer . . . 9
4.3.5 Management Segment . . . 9
4.4 Site: Groningen (Secondary) . . . 9
4.5 Inter-Site Connectivity . . . 9
4.6 ArchiMate Technology Layer View . . . 10
4.7 Architectural Decisions and Trade-offs . . . 10
4.7.1 On-premises vs. Cloud . . . 10
4.7.2 RabbitMQ vs. Kafka . . . 10
4.7.3 PostgreSQL vs. a Single Database Type . . . 10
4.7.4 Groningen WMS Autonomy . . . 10

5 Requirements Analysis **12**
5.1 Management Requirements . . . 12
5.2 User Requirements . . . 12
5.3 Functional Requirements . . . 12
5.4 Non-Functional Requirements . . . 12
5.4.1 Availability . . . 12
5.4.2 Performance . . . 12
5.4.3 Security . . . 13
5.4.4 Scalability and Capacity . . . 13

6 Assignments **15**
6.1 Assignment 2 – Business Service to Technical Service Mapping . . . 15
6.1.1 Service Mapping . . . 15

6.1.2 Dependency Analysis . . . 15
6.1.3 Dashboard Design . . . 15
6.2 Assignment 3 – Status and Performance Monitoring Solution . . . 17
6.2.1 Scope and Objectives . . . 17
6.2.2 Architecture . . . 17
6.2.3 Alert Thresholds . . . 17
6.2.4 Groningen Site Monitoring . . . 17
6.2.5 SLA Reporting . . . 18
6.3 Assignment 7 – Logging and Forensic Data Collection . . . 18
6.3.1 Objectives . . . 18
6.3.2 Log Sources . . . 19
6.3.3 Centralised Log Architecture . . . 19
6.3.4 Retention Policy . . . 19
6.3.5 Forensic Readiness . . . 19
6.3.6 Information Flow . . . 20
6.3.7 GDPR Considerations . . . 21

1 Introduction

1.1. Purpose of This Document

This document presents the Week 2 architectural foundation for the ICT Infrastructure Case Study. The assignment requires the role of an Enterprise Infrastructure Architect, responsible for researching, designing, justifying and advising on enterprise infrastructure and monitoring solutions.

The approach taken in this document is grounded in TOGAF as the enterprise architecture framework and ArchiMate as the modelling language. Rather than treating infrastructure design as a standalone technical exercise, all decisions are derived from and traced back to the business context, stakeholder needs and identified risks.

This chapter establishes the enterprise context (Step 0), which serves as the foundation for all architectural decisions in subsequent chapters.

1.2. Assumptions and Scope

All infrastructure and monitoring designs in this document are based on the enterprise context described below. Where assumptions were made, they are explicitly stated. No implementation or system administration tasks are within scope — this document focuses on research, design and architectural advice.

2

Enterprise Context

2.1. Organisation Overview

The organisation used throughout this case study is **LogiFlux B.V.**, a fictitious Dutch regional wholesale distribution company operating in the Fast-Moving Consumer Goods (FMCG) sector. LogiFlux acts as an intermediary between product suppliers and retail customers, managing the full chain from goods intake and warehousing through to order fulfilment and delivery.

- **Legal form:** Private limited company (B.V.), incorporated in the Netherlands
- **Sector:** Wholesale distribution — FMCG
- **Founded:** 2009
- **Annual revenue (estimated):** €42 million
- **Customers:** Retail chains, independent supermarkets and hospitality businesses

2.2. Locations

LogiFlux operates from two permanent physical sites:

- **Eindhoven (HQ + Primary Distribution Centre):** The main site houses the executive team, IT department, finance, HR, customer service and the primary warehouse and distribution operations.
- **Groningen (Secondary Distribution Centre):** A second warehouse and distribution facility serving customers in the northern Netherlands. This site operates under the management of a regional operations manager reporting to Eindhoven.

The two sites are approximately 220 km apart and are connected via a leased MPLS WAN link with a redundant internet-based VPN failover path.

2.3. Organisational Structure

LogiFlux employs approximately 200 staff distributed as follows:

2.4. Core Business Processes

The following core business processes drive all infrastructure and monitoring requirements:

1. **Customer Order Management** — Retail customers place orders via the customer portal (web-based) or by telephone via customer service representatives. Orders are processed, validated against inventory and scheduled for fulfilment.

Department	Headcount	Primary Site
Distribution Centre (warehouse, logistics, drivers)	120	Both (70 EHV / 50 GRN)
Customer Service	24	Eindhoven
Administration (Finance & HR)	12	Eindhoven
IT	10	Eindhoven
Management	8	Eindhoven
Maintenance & Support	26	Both
Total	**200**	

Table 2.1: Personnel distribution across departments and sites

2. **Goods Storage and Distribution** — Warehouse staff receive, store and pick goods across both distribution centres. The system manages inventory levels, triggers replenishment and coordinates outbound logistics.
3. **Financial Administration and Accounting** — The finance department processes invoices, manages accounts payable and receivable, and produces financial reporting. This process is subject to Dutch regulatory requirements (Belastingdienst, GDPR).
4. **Salary Administration and Personnel Registration** — HR manages contracts, payroll, attendance records and personnel data. This is a high-sensitivity process due to the personal and financial data involved.

2.5. Business Criticality and Risk Profile

LogiFlux operates in a time-sensitive distribution environment. Order processing and warehouse management systems must be available during operational hours, and the customer portal must be accessible at all times.

Business Process	Criticality	Risk / Impact of Downtime
Customer Order Management	High	Loss of orders, SLA breach, revenue impact, customer churn
Goods Storage & Distribution	High	Operational standstill, delivery delays, contractual penalties
Financial Administration	Medium	Delayed invoicing, regulatory non-compliance
Salary & HR Administration	Medium	Payroll errors, GDPR non-compliance, staff dissatisfaction

Table 2.2: Business process criticality and risk overview

Key risk factors for LogiFlux include:

- **Seasonal peak loads:** Customer traffic can spike from approximately 1,200 to 10,000 transactions per day during promotional periods (e.g. holidays, end-of-quarter campaigns). Infrastructure must handle these peaks without degradation.
- **Single point of failure at Groningen:** The secondary site has limited local IT staff, making remote management and monitoring critical.
- **Data sensitivity:** Financial records, payroll data and customer purchase histories are all subject to GDPR and must be protected.
- **Supply chain dependencies:** Integration with supplier systems via EDI creates external dependency risks.
- **Ransomware and business email compromise:** As a mid-size distribution company with financial transaction exposure, LogiFlux is a realistic target for financially motivated attackers.

2.6. Key Stakeholders and Their Interests

Stakeholder	Interests and Concerns
CEO / Board	Business continuity, cost efficiency, regulatory compliance, reputation
Operations Director	Availability of order and warehouse systems during operational hours
IT Director	Infrastructure reliability, security posture, manageability, scalability
Finance Manager	Data integrity of accounting systems, audit trails, regulatory compliance
HR Manager	Privacy and integrity of personnel data (GDPR), payroll accuracy
Customer Service Team	Reliable access to the customer order system, fast issue resolution
Retail Customers	Order accuracy, portal availability, delivery reliability, data privacy
Distribution Staff	Reliable warehouse management systems, minimal downtime during shifts

Table 2.3: Key stakeholders and their interests

2.7. Customer Load and Capacity Assumptions

- **Average daily load:** approximately 1,200 customer transactions
- **Peak daily load:** up to 10,000 customer transactions (seasonal spikes)
- **Peak-to-average ratio:** approximately 8:1 — infrastructure must be designed to handle peak load without significant over-provisioning during baseline periods
- **Operating hours:** Monday–Friday, 07:00–18:00 for warehouse operations; customer portal available 24/7
- **Internal users:** approximately 200 concurrent users maximum, with peak usage during morning shift handover (07:00–09:00)

2.8. Summary of Assumptions

The following assumptions underpin this entire document:

1. LogiFlux B.V. is a fictional organisation. Any resemblance to real companies is coincidental.
2. Both physical sites are in the Netherlands; all regulations referenced are Dutch/EU.
3. The IT department (10 staff) is responsible for all infrastructure, with no dedicated security operations centre (SOC). Security monitoring is managed by the IT team.
4. No existing enterprise architecture documentation is assumed to exist; this document represents a greenfield design.
5. Cloud services may be used where cost-effective and appropriate; on-premises infrastructure is preferred for sensitive data.
6. The leased MPLS link between sites provides the primary inter-site connectivity; an internet-based VPN acts as failover.

3

Architecture Method

3.1. Overview

This document applies **TOGAF** (The Open Group Architecture Framework) as its guiding enterprise architecture method, with **ArchiMate** as the modelling language for expressing architectural views. These are not merely referenced in name — they actively structure how analysis is conducted, how decisions are documented, and how diagrams are constructed.

3.2. TOGAF and the Architecture Development Method

TOGAF's core process is the **Architecture Development Method (ADM)**, an iterative cycle of phases for developing and maintaining enterprise architecture. For this case study, the following phases are directly applied:

ADM Phase	Application in This Document
Preliminary	Establishing the architectural approach, scope, and principles. Defines that TOGAF and ArchiMate are used and why.
Phase A — Architecture Vision	Step 0 (Enterprise Context): defining the organisation, stakeholders, business goals and risk profile that drive all architectural decisions.
Phase B — Business Architecture	Step 3 (Requirements Analysis): deriving requirements from business processes and stakeholder concerns.
Phase C — Information Systems Architecture	Step 2 (Infrastructure Design): mapping business services to application and data components.
Phase D — Technology Architecture	Step 2 (Infrastructure Design): designing the physical and virtual infrastructure, network segmentation, server clusters and connectivity.
Phase E — Opportunities & Solutions	Step 4 (Monitoring Design): identifying monitoring solutions that address gaps identified during the architecture phases.

Table 3.1: TOGAF ADM phases applied in this document

TOGAF's principle of **traceability** is applied throughout: every infrastructure component and monitoring decision is traceable back to a business requirement, stakeholder concern, or identified risk defined in the enterprise context.

3.3. ArchiMate as Modelling Language

ArchiMate is an open modelling language standardised by The Open Group, designed to describe, analyse and visualise enterprise architectures across multiple domains. It is used in this document to produce architecture diagrams that are consistent, unambiguous and layered.

ArchiMate organises elements across three **layers**:

- **Business Layer** — represents business processes, roles, functions and services as experienced by stakeholders (e.g. Customer Order Management, Salary Administration).
- **Application Layer** — represents the software applications and services that support business processes (e.g. order management system, IAM/SSO, ERP).
- **Technology Layer** — represents the physical and virtual infrastructure that hosts applications (e.g. server clusters, VLANs, firewalls, storage, WAN links).

Relationships between elements (such as *realisation*, *serving*, *assignment* and *composition*) are used to make dependencies and interactions explicit. This prevents the common pitfall of designing infrastructure in isolation from the business functions it must support.

3.4. How the Method Influenced This Work

The choice of TOGAF and ArchiMate had concrete effects on the structure and content of this document:

1. **Enterprise context first.** Following ADM Phase A, the enterprise context was defined before any technical design began. Infrastructure choices are consequences of business needs, not the other way around.
2. **Layered diagrams.** All architecture diagrams use ArchiMate notation to clearly separate business, application and technology concerns, making dependencies visible and reviewable.
3. **Stakeholder-driven requirements.** ADM Phase B drives the requirements analysis — each requirement is attributed to a stakeholder, business process or risk, rather than being a generic technical wish-list.
4. **Justified decisions.** TOGAF's emphasis on architectural decisions with rationale means that every significant infrastructure choice in this document is accompanied by a justification and trade-off discussion.

4

Enterprise Infrastructure Architecture

4.1. Architectural Principles

The following principles govern all infrastructure design decisions for LogiFlux B.V. They are derived from the enterprise context, stakeholder concerns, and TOGAF's concept of architecture principles as guiding constraints.

1. **Separation of concerns.** The infrastructure is divided into clearly isolated segments (DMZ, Application, Database, Management, Client). No segment communicates with another unless explicitly required and controlled by a firewall rule.
2. **Defence in depth.** Multiple layers of security controls are applied. External traffic passes through a perimeter firewall before reaching the DMZ. Internal application traffic passes through an additional internal firewall before reaching application servers.
3. **Least privilege access.** Application servers can only be reached through the front-end. Database servers can only be reached by application servers. No direct external access to backend systems is permitted.
4. **High availability.** Business-critical components (web cluster, application clusters, message broker, database clusters) are clustered to eliminate single points of failure. Both sites are independently operational.
5. **Scalability for peak loads.** The front-end web cluster is auto-provisioned to handle the 8:1 peak-to-average customer load ratio. The NoSQL database layer supports high-throughput request handling during peak periods.
6. **Traceability.** Every infrastructure component maps directly to one or more business processes defined in the enterprise context.

4.2. Network Segmentation

The infrastructure is segmented using VLANs. Each VLAN corresponds to a logical security zone. Inter-VLAN traffic is routed through firewall policies, not open routing. The VLAN design is consistent across both sites, with separate IP ranges per site to avoid conflicts.

IP addressing follows a consistent scheme: Eindhoven uses the `10.0.x.0/24` range (where `x` is the VLAN ID), and Groningen uses `10.1.x.0/24`. Inter-site WAN connectivity uses `10.10.0.0/30`. The IAM server resides in the DMZ at a static address accessible from all VLANs.

4.3. Site: Eindhoven (Primary)

Eindhoven is the primary site hosting all core application workloads. It serves both local staff and all external customers.

VLAN ID	Name	Purpose and Key Components
10	DMZ	Public-facing services: load balancer, auto-provisioned web cluster, SSL/TLS termination. All inbound internet traffic enters here.
20	Application	Isolated application server clusters (Order System, Accounting, HR/Payroll, Warehouse). Accessible only via Internal Firewall from DMZ.
30	Message Broker	RabbitMQ cluster, isolated from both App and DB VLANs. Accessed by App clusters via broker API only.
40	Database	PostgreSQL (relational) and MongoDB (NoSQL) clusters. No direct access from DMZ or clients.
50	Management	Monitoring server, jump host, configuration management. Administrative access only via IAM-authenticated session.
60	Client	Staff Windows endpoints. Outbound internet access via proxy; inbound access to applications via web browser through DMZ.

Table 4.1: VLAN segmentation design for LogiFlux B.V.

4.3.1. Perimeter and DMZ

Inbound internet traffic (customer portal, staff remote access) terminates at the perimeter firewall. All allowed traffic is forwarded to the load balancer in the DMZ, which distributes requests across the auto-provisioned web cluster. The web cluster handles HTTP/HTTPS and communicates only with the application layer via the internal firewall.

The **Identity and Access Management (IAM)** server is co-located in the DMZ at a static address. It provides Single Sign-On (SSO) and role-based access control for all applications. Users authenticate once against the IAM before being granted access to any application, regardless of which cluster handles the request.

4.3.2. Application Server Clusters

Four isolated application clusters run in the Application VLAN. Each cluster is independently deployable and contains a mix of Windows and Linux nodes depending on the application stack's requirements.

Cluster	OS Mix	Function
Customer Order System	Linux	Handles customer order submission, validation, status tracking and the public customer portal. Highest traffic volume; primary consumer of the NoSQL DB for read-heavy requests.
Accounting	Windows	Processes invoices, accounts payable/receivable, financial reporting. Strict audit logging required. Writes exclusively to the relational database.
HR / Salary Administration	Windows	Manages personnel records, payroll, contracts and attendance. High data sensitivity; access restricted by role in IAM.
Goods Storage & Distribution	Linux	Warehouse management system (WMS): inventory, pick lists, inbound/outbound logistics. Publishes events to RabbitMQ for order fulfilment triggers.

Table 4.2: Application server clusters and their functions

4.3.3. Message Broker: RabbitMQ

A RabbitMQ cluster resides in the dedicated Message Broker VLAN, isolated from both the Application and Database VLANs. It provides asynchronous event-driven communication between application clusters, decoupling producers from consumers and improving resilience during peak load.

The primary message flows are:

- **Order System → Warehouse:** When a customer order is confirmed, an event is published to a queue consumed by the Warehouse cluster. This decouples the order creation flow from warehouse picking, preventing order spikes from directly impacting warehouse throughput.
- **Order System → Accounting:** Confirmed orders trigger invoice creation events consumed by the Accounting cluster asynchronously, keeping financial processing out of the synchronous order path.
- **Groningen inventory sync:** Inventory updates from the Groningen WMS node are published to a queue and replicated to the Eindhoven Warehouse cluster, ensuring consistent stock levels across sites even during brief WAN interruptions (messages queue and deliver on reconnect).

4.3.4. Backend: Database Layer

The database layer runs in a dedicated DB VLAN with no direct external access. Two clustered database systems are provided:

- **PostgreSQL (relational):** Serves the Accounting, HR/Payroll and Order System clusters for transactional, structured data requiring ACID compliance. A hot-standby replica in Eindhoven provides failover. A read replica is deployed in Groningen for local WMS queries.
- **MongoDB (NoSQL):** Serves the Customer Order System for high-throughput, read-heavy customer request handling. Its flexible document model accommodates variable order structures and scales horizontally to absorb peak loads (up to 10,000 transactions per day).

4.3.5. Management Segment

The Management VLAN contains a monitoring server (collecting metrics, logs and health data from all infrastructure components) and a jump host. All administrative access to servers is routed through the jump host, which enforces IAM authentication and session logging. Direct SSH or RDP access from the Client VLAN to production servers is not permitted.

4.4. Site: Groningen (Secondary)

Groningen is a secondary distribution site with limited local IT staff. Its infrastructure is designed for operational independence in the event of a WAN failure, while staying synchronised with Eindhoven under normal conditions.

- **Perimeter firewall:** Provides site-level security and manages the MPLS/VPN WAN connection.
- **Client VLAN:** Approximately 50 Windows endpoints used by warehouse and distribution staff. Applications are accessed via the customer-facing portal hosted in Eindhoven (browser-based, no local app servers for most functions).
- **WMS Node:** A local Warehouse Management System node that can operate offline in read/write mode during a WAN outage, using a local database cache. Changes are queued and synchronised via RabbitMQ once the WAN link is restored.
- **PostgreSQL Read Replica:** A read replica of the Eindhoven PostgreSQL cluster, reducing WAN latency for WMS read queries and providing a local fallback for inventory queries during WAN disruption.

4.5. Inter-Site Connectivity

The two sites are connected via:

- **Primary:** A leased MPLS link providing a guaranteed bandwidth of at least 100 Mbit/s with low latency. This link carries all application traffic between sites, including database replication and RabbitMQ message sync.
- **Failover:** An internet-based IPSec VPN that activates automatically if the MPLS link fails. The failover link provides reduced bandwidth (minimum 20 Mbit/s) but ensures continuity for critical WMS and database replication traffic.

All inter-site traffic is encrypted at the network layer regardless of whether MPLS or VPN is in use.

4.6. ArchiMate Technology Layer View

The diagram below presents the technology layer view of the LogiFlux B.V. enterprise infrastructure using ArchiMate notation. Element types are annotated in italic above each element name. Colours indicate the ArchiMate element category per the legend.

4.7. Architectural Decisions and Trade-offs

4.7.1. On-premises vs. Cloud

Sensitive data workloads (HR/Payroll, Accounting) are hosted on-premises to maintain full control over GDPR-governed data and avoid dependency on third-party cloud providers. The Customer Order System and MongoDB layer are candidates for future cloud migration if scaling demands exceed on-premises capacity, particularly given the 8:1 peak-to-average ratio.

4.7.2. RabbitMQ vs. Kafka

RabbitMQ was selected over Apache Kafka for the message broker layer. At LogiFlux's current scale (order of thousands of daily transactions), RabbitMQ's lower operational overhead and simpler queue management model are better suited to a 10-person IT team. Kafka's log-based architecture offers better throughput at much larger scale but introduces significant operational complexity that is disproportionate to LogiFlux's needs.

4.7.3. PostgreSQL vs. a Single Database Type

A deliberate decision was made to deploy both a relational (PostgreSQL) and a NoSQL (MongoDB) database rather than relying on a single database type. The relational model is required for transactional integrity in financial and HR processes. The NoSQL model is required for the high-throughput, read-heavy customer portal workload. Forcing all workloads into a single database type would require either sacrificing ACID compliance for financial data or accepting poor performance on the customer-facing side.

4.7.4. Groningen WMS Autonomy

The Groningen WMS node is designed to continue operating in degraded mode during a WAN outage by using a local PostgreSQL read replica and an offline write queue. This design choice accepts the risk of brief data inconsistency (resolved on WAN recovery via RabbitMQ replay) in exchange for operational continuity at the distribution site. A full WAN outage would otherwise halt all warehouse operations at Groningen.

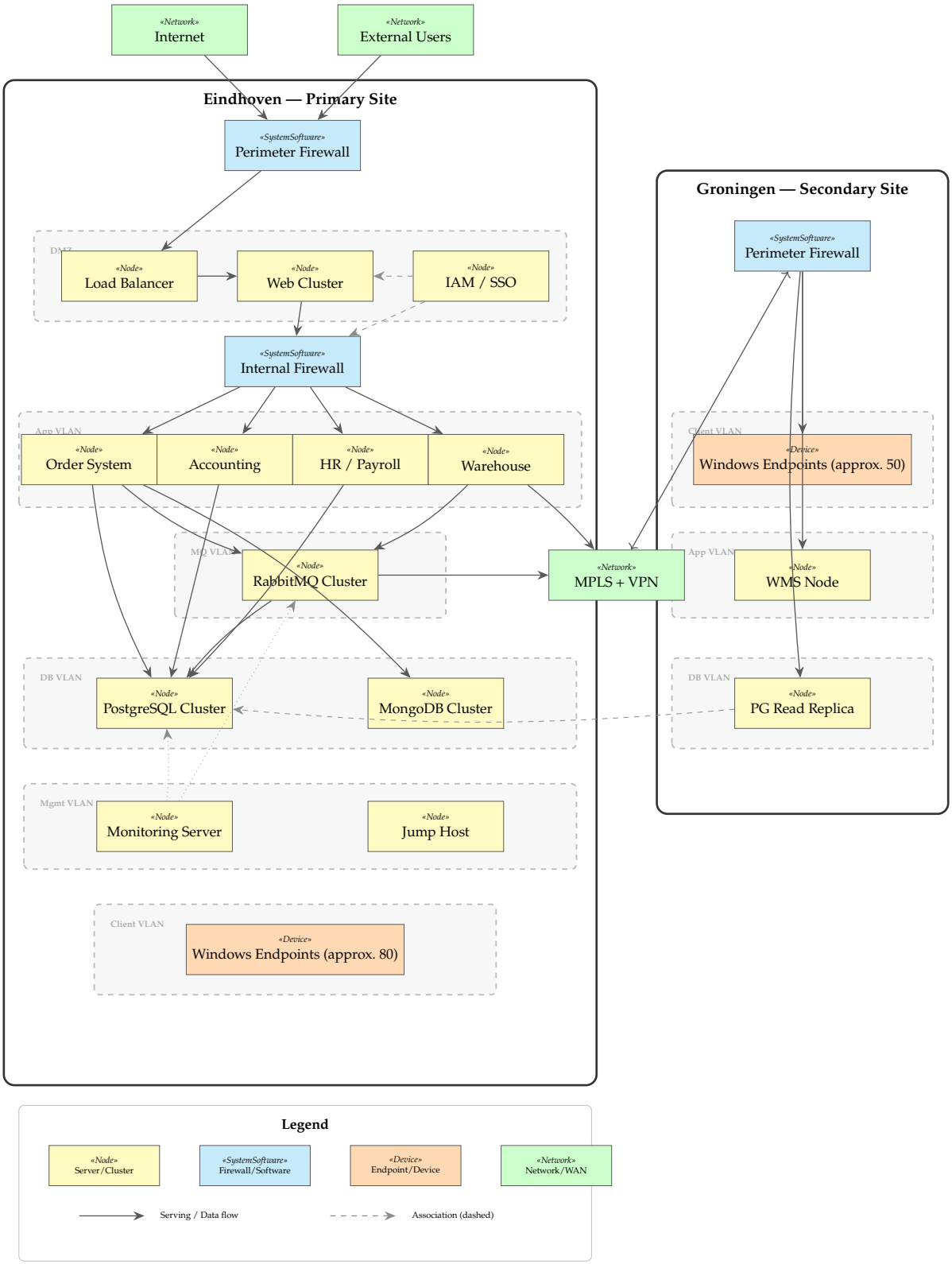

Figure 4.1: ArchiMate Technology Layer View — LogiFlux B.V. Enterprise Infrastructure

5

Requirements Analysis

This chapter applies TOGAF ADM Phase B (Business Architecture) to derive requirements from the enterprise context, stakeholder concerns and identified risks defined in Chapter 2. Requirements are not generated from technical preferences; each requirement is explicitly traced to a source.

5.1. Management Requirements

ID	Source	Requirement
MR-01	IT Director	All production infrastructure components must be visible in a single monitoring dashboard, aggregating status, performance and alerts from both sites.
MR-02	IT Director	Automated alerting must notify on-call IT staff within 2 minutes of a critical component failure (P1 threshold).
MR-03	Operations Director	Operational dashboards for Order System and Warehouse must be available to non-IT staff (read-only, role-restricted views).
MR-04	CEO / Board	Monthly availability reports must be generated automatically for the Customer Order System and customer portal, to support SLA validation.
MR-05	IT Director	All administrative access to production servers must be logged and auditable, traceable to an individual IAM identity.
MR-06	IT Director	Infrastructure capacity data (CPU, memory, storage trends) must be retained for a minimum of 13 months to support annual capacity planning cycles.

Table 5.1: Management requirements

5.2. User Requirements

ID	Source	Requirement
UR-01	Customer Service Team	The customer order portal must be accessible 24/7 with degraded-mode notifications published on a status page when planned maintenance is in progress.
UR-02	Distribution Staff (EHV, GRN)	The Warehouse Management System must remain operational during a WAN outage between sites (offline mode requirement).
UR-03	Finance Manager	The Accounting system must provide a complete, immutable audit trail of all financial transactions, accessible to authorised Finance staff for at least 7 years (Dutch fiscal law requirement).
UR-04	HR Manager	Access to the HR/Payroll system must be role-restricted; no IT staff member may access payroll data without explicit authorisation from the HR Manager.
UR-05	IT Staff	A jump host with session recording must be the only path to production servers, enabling post-incident forensic review of all administrative sessions.
UR-06	Retail Customers	The customer portal response time must not exceed 2 seconds for standard order operations under normal load conditions.

Table 5.2: User requirements

5.3. Functional Requirements

ID	Source	Requirement
FR-01	Order Management	The Order System must support concurrent processing of at least 10,000 customer transactions per day during seasonal peaks without service degradation.
FR-02	Warehouse / Distribution	Inventory events from both sites must be synchronised via the RabbitMQ message broker, with guaranteed delivery and replay capability on WAN recovery.
FR-03	Accounting	Invoice creation events must be published asynchronously by the Order System so that accounting processing does not block the order submission path.
FR-04	HR / Payroll	Payroll data must be encrypted at rest and in transit. Access must be logged at the application level with user identity, timestamp and action.
FR-05	IAM / Access	All application access must require SSO authentication through the IAM. Direct database or server access bypassing the IAM is not permitted.
FR-06	Monitoring	Metrics, logs and health data from all infrastructure components must be collected centrally in the Management VLAN.
FR-07	Groningen WMS	The WMS node in Groningen must queue write operations locally and replay them to the central cluster when the WAN link is restored.

Table 5.3: Functional requirements

5.4. Non-Functional Requirements

5.4.1. Availability

ID	System	Target	Justification
NFR-AV-01	Customer Portal	99.9%	Revenue-critical; 24/7 customer access. Allows ≤8.7 hours downtime per year.
NFR-AV-02	Order System	99.9%	Core revenue process; direct SLA impact on retail customers.
NFR-AV-03	Warehouse / WMS	99.5% (during ops hours)	Operational hours 07:00–18:00; brief degraded mode acceptable outside hours.
NFR-AV-04	Accounting	99.0%	Business-hours only; brief outages outside office hours are acceptable.
NFR-AV-05	HR / Payroll	99.0%	Monthly payroll cycle; sustained availability required only around pay dates.
NFR-AV-06	IAM / SSO	99.9%	A single IAM failure prevents access to all applications; must match portal SLA.

Table 5.4: Availability requirements (NFR)

5.4.2. Performance

- **NFR-PERF-01:** Customer portal page load time ≤ 2 seconds under normal load (1,200 transactions/day). Source: UR-06.
- **NFR-PERF-02:** Customer portal page load time ≤ 5 seconds under peak load (10,000 transactions/day). The web cluster auto-scaling must absorb the 8:1 peak-to-average ratio.
- **NFR-PERF-03:** RabbitMQ message processing latency ≤ 500 ms under normal load. Source: FR-03.
- **NFR-PERF-04:** Database query response time ≤ 200 ms for 95% of PostgreSQL queries under normal conditions. Source: FR-01.
- **NFR-PERF-05:** WAN failover (MPLS → IPSec VPN) must complete within 60 seconds without manual intervention.

5.4.3. Security

- **NFR-SEC-01:** All data in transit between VLANs, sites and external parties must be encrypted (TLS 1.2 minimum; TLS 1.3 preferred). Source: legal / GDPR.
- **NFR-SEC-02:** All data at rest in the HR/Payroll and Accounting clusters must be encrypted using AES-256 or equivalent. Source: UR-04, GDPR.
- **NFR-SEC-03:** Multi-factor authentication (MFA) must be enforced for all IT staff, management and Finance/HR roles via the IAM. Source: IT Director, risk profile.
- **NFR-SEC-04:** Firewall rule changes must be logged, version-controlled and require dual approval from IT management. Source: MR-05.
- **NFR-SEC-05:** Security logs must be retained for a minimum of 12 months online and 36 months in cold storage. Source: GDPR Article 5(1)(e), incident response requirements.

5.4.4. Scalability and Capacity

- **NFR-CAP-01:** The web cluster must auto-scale horizontally to handle the 8:1 peak-to-average load ratio without manual intervention.

- **NFR-CAP-02:** MongoDB must be capable of horizontal shard expansion to accommodate customer base growth of up to 300% without architectural redesign.
- **NFR-CAP-03:** Storage capacity for all systems must include a minimum 30% headroom above projected 12-month utilisation.
- **NFR-CAP-04:** Capacity metrics must trigger a planning review alert when any critical resource exceeds 70% of provisioned capacity sustained over 7 days.

6

Assignments

This chapter addresses four of the seven optional assignments. Assignment 1 (combined network and functional architecture diagram) has already been completed in Chapter 4, Section 4.6, using ArchiMate notation and TikZ. The three assignments addressed in full here are:

- **Assignment 2** — Map business services to technical services and explain how this mapping could be represented in a dashboard.
- **Assignment 3** — Design a solution for status and performance monitoring of all servers.
- **Assignment 7** — Design a solution for logging and forensic data collection.

6.1. Assignment 2 – Business Service to Technical Service Mapping

6.1.1. Service Mapping

An enterprise monitoring strategy must not only observe infrastructure components in isolation but must express the health of infrastructure in terms that are meaningful to the business. This requires an explicit mapping between business services (as understood by stakeholders) and the technical services and components that realise them.

Table 6.1 presents the full service mapping for LogiFlux B.V., tracing each business service through the application layer to the underlying infrastructure components.

Business Service	Application Layer	Dependent Infrastructure Components
Customer Order Portal	Order System Cluster	Perimeter FW, Load Balancer, Web Cluster, IAM/SSO, Internal FW, Order System Cluster, MongoDB Cluster, RabbitMQ Cluster, PostgreSQL Cluster
Goods Storage & Distribution	Warehouse Cluster (EHV + GRN)	Internal FW, Warehouse Cluster, RabbitMQ Cluster, PostgreSQL Cluster, WAN link (MPLS/VPN), Groningen FW, WMS Node (GRN), PG Read Replica (GRN)
Financial Administration	Accounting Cluster	Internal FW, Accounting Cluster, PostgreSQL Cluster, RabbitMQ Cluster (invoice events)
Salary & Personnel Administration	HR / Payroll Cluster	Internal FW, HR/Payroll Cluster, PostgreSQL Cluster
Identity and Access Management	IAM / SSO Server	Perimeter FW, IAM/SSO Node, PostgreSQL Cluster (user store)
IT Operations and Management	Monitoring Server, Jump Host	Management VLAN, Monitoring Server, Jump Host, IAM/SSO (admin authentication)

Table 6.1: Business service to technical service mapping

6.1.2. Dependency Analysis

The mapping reveals two critical shared dependencies that affect multiple business services simultaneously:

1. **IAM / SSO Node:** A failure of the IAM/SSO node would render all six business services inaccessible, as every application requires authentication. This justifies its NFR-AV-06 availability target of 99.9% and the recommendation to deploy it as a clustered pair.
2. **PostgreSQL Cluster:** Four of the six business services depend on PostgreSQL. A total PostgreSQL failure would halt financial administration, HR/payroll, IAM authentication and the relational component of order processing. The hot-standby replica in Eindhoven and the automatic failover mechanism (via a connection pooler such as PgBouncer with health-check failover) are therefore non-negotiable.

6.1.3. Dashboard Design

Design Principles

The monitoring dashboard follows three principles derived from the stakeholder analysis:

- **Business-first view:** The primary dashboard view presents service health in business terms (e.g. "Customer Order Portal: Operational"), not server metrics. Stakeholders without IT backgrounds (Operations Director, CEO) must be able to interpret the dashboard immediately.
- **Role-based access:** Different stakeholders see different levels of detail. Business managers see service-level indicators (green/amber/red). IT staff see the underlying component metrics. No role sees data outside their responsibility.
- **Drill-down capability:** Each business service indicator links to a second-level view showing the contributing technical components. A third level provides raw metrics and logs.

Dashboard Structure

The dashboard is structured across three tiers:

Tier 1 — Executive / Business View (read-only, all authenticated users)

- Six status tiles, one per business service, showing current operational state: **Operational**, **Degraded** or **Unavailable**.
- A 24-hour availability sparkline per service (percentage of time in "Operational" state).

- A current incident banner if any P1 or P2 incident is active.

Tier 2 — Operations View (IT staff and relevant department managers)

- Per-service component health matrix: each infrastructure component contributing to the service, showing health state, latency and last check timestamp.
- Key performance indicators: Order System request rate and error rate; Warehouse message queue depth; database replication lag.
- WAN link status (MPLS primary / VPN failover) with bandwidth utilisation.

Tier 3 — Engineering View (IT staff only)

- Individual server dashboards: CPU, memory, disk I/O, network throughput, process count.
- Database dashboards: query throughput, lock contention, replication lag (seconds), slow query log.
- RabbitMQ dashboards: queue depth per queue, consumer lag, message publish and ack rates.
- Firewall dashboards: connection table utilisation, blocked connection counts, bandwidth per VLAN.

Tooling Recommendation

Grafana is recommended as the dashboard platform, consuming metrics from **Prometheus** (time-series metrics) and **Loki** (log aggregation). This stack is open-source, runs on the existing monitoring server in the Management VLAN, and supports role-based access control via LDAP/SAML integration with the IAM. Grafana's "status panel" plugin directly supports the traffic-light service health tiles described in Tier 1.

6.2. Assignment 3 – Status and Performance Monitoring Solution

6.2.1. Scope and Objectives

This monitoring solution addresses status and performance monitoring for all server-class infrastructure components in the LogiFlux environment, across both sites. The objectives, derived from the requirements in Chapter 5, are:

- Provide real-time visibility into the operational state of all production servers.
- Detect failures and degraded performance before they impact business services.
- Support proactive capacity planning (NFR-CAP-01 through NFR-CAP-04).
- Deliver automated alerting within 2 minutes of a critical failure (MR-02).
- Provide data for SLA reporting (MR-04).

6.2.2. Architecture

The monitoring architecture follows an **agent-based collection model**: a lightweight metrics agent runs on each monitored host and pushes or exposes data to a central Prometheus server in the Management VLAN. This avoids the need to open inbound firewall rules to production servers and reduces the attack surface.

- **Metrics collection:** Prometheus with **node_exporter** on all Linux hosts and **windows_exporter** on all Windows hosts. Additional exporters are deployed per service type (see Table 6.2).
- **Storage:** Prometheus retains 15 days of high-resolution (15-second interval) metrics locally. Data is downsampled and forwarded to **Thanos** or **VictoriaMetrics** for the 13-month long-term retention required by MR-06.
- **Visualisation:** Grafana (as described in Assignment 2) provides dashboards for all tiers of stakeholders.

- **Alerting:** Prometheus **Alertmanager** routes alerts by severity to on-call IT staff via PagerDuty (P1/P2) and to a Teams/Slack channel (P3/informational). The 2-minute detection-to-notification requirement (MR-02) is met by a 1-minute scrape interval for critical components and a 1-minute alert evaluation cycle.

Component	Exporter / Agent	Key Metrics Collected
All Linux servers	node_exporter	CPU (user/sys/iowait), memory (used/cached/available), disk I/O (read/write IOPS, latency), network (bytes in/out, errors), load average, uptime
All Windows servers	windows_exporter	CPU utilisation, memory commit, disk queue length, network interface throughput, Windows event log counters, service state
PostgreSQL	postgres_exporter	Connections (active/idle/waiting), transactions per second, replication lag (seconds), cache hit ratio, deadlocks, longest running query duration
MongoDB	mongodb_exporter	Operations per second (reads/writes/commands), memory resident set, replication oplog window, connections, collection scan counts
RabbitMQ	rabbitmq_exporter	Queue depth per queue, message publish/deliver/ack rates, consumer count per queue, unacknowledged messages, memory and disk alarms
Firewalls (pfSense/OPNsense)	pfsense_exporter / SNMP	Connection table utilisation (%), blocked packets/s, bandwidth per interface, CPU/memory of firewall appliance
WAN link	SNMP on WAN router	Interface bandwidth utilisation (%), packet loss (%), round-trip latency (ms) to Groningen, link state

Table 6.2: Exporters and key metrics per infrastructure component

6.2.3. Alert Thresholds

Alert thresholds are defined at two levels. **P1** alerts require immediate response (on-call engineer notified within 2 minutes). **P2** alerts require same-day response. **P3** alerts are informational and visible in the dashboard only.

Metric	P1 (Critical)	P2 (Warning)	Notes
Server CPU utilisation	>90% for 5 min	>70% for 10 min	Applies to all production nodes
Server memory available	<5% for 5 min	<15% for 10 min	
Disk space remaining	<5%	<15%	Evaluated per-mount
Disk I/O latency	>50 ms avg	>20 ms avg	
Server unreachable	Immediate (node down)	—	Exporter target disappears from Prometheus
PostgreSQL replication lag	>30 s	>10 s	Triggers before standby falls too far behind
PostgreSQL connections	>90% of max	>75% of max	
RabbitMQ queue depth	>10,000 messages	>5,000 messages	Per business-critical queue
WAN link utilisation	>90% sustained	>70% sustained	MPLS or VPN link
WAN packet loss	>5%	>1%	Over a 5-minute window

Table 6.3: Alert thresholds for status and performance monitoring

6.2.4. Groningen Site Monitoring

The monitoring server in Eindhoven's Management VLAN collects metrics from Groningen components over the WAN link. Groningen exporters are scraped by the central Prometheus instance via the MPLS link. A **blackbox exporter** probe is run from Eindhoven to the Groningen firewall's management IP every 30 seconds to provide independent WAN liveness detection.

In the event of a WAN failure, Prometheus marks all Groningen targets as *unreachable* and fires a P1 alert. If a local monitoring agent is desired at the Groningen site, a lightweight **Prometheus remote write agent** (Grafana Agent or Prometheus in agent mode) can buffer metrics locally and forward them when the WAN recovers.

6.2.5. SLA Reporting

Grafana's built-in **SLA/availability reporting** capability generates monthly reports from Prometheus availability data. The report for the Customer Order Portal (NFR-AV-01: 99.9%) is calculated as:

$$\text{Availability} = \frac{\text{Total minutes in month} - \text{Minutes in P1 outage state}}{\text{Total minutes in month}} \times 100\%$$

These reports are exported as PDF and sent automatically to the IT Director and Operations Director at the end of each calendar month (MR-04).

6.3. Assignment 7 – Logging and Forensic Data Collection

6.3.1. Objectives

A centralised logging and forensic readiness solution serves three distinct purposes at LogiFlux:

1. **Operational logging:** Capturing application and system events to support incident diagnosis, troubleshooting and root-cause analysis.
2. **Compliance logging:** Retaining audit trails required by Dutch law (fiscal records: 7 years), GDPR (access logs and data processing records) and internal policy.
3. **Forensic readiness:** Ensuring that in the event of a security incident, sufficient evidence is available in an admissible, tamper-evident form to support investigation and legal proceedings.

6.3.2. Log Sources

Table 6.4 enumerates all log sources in the LogiFlux environment and their classification.

Source	Category	Log Types and Content
Perimeter Firewalls (EHV, GRN)	Security / Network	Connection allowed/denied, NAT translations, IDS/IPS alerts, interface state changes
Internal Firewall (EHV)	Security / Network	Inter-VLAN traffic decisions, policy violation events
Load Balancer	Operational	HTTP access log (method, URI, response code, client IP, response time), backend health check results
Web Cluster	Operational	Application access logs, HTTP error logs, SSL handshake errors
IAM / SSO Server	Security / Compliance	Authentication events (success/failure), MFA events, session creation/destruction, role assignment changes
Application Clusters (all four)	Operational / Compliance	Application error logs, user action audit logs (for Accounting and HR), inter-service API call logs
RabbitMQ Cluster	Operational	Message publish/consume/ack/nack events, queue creation/deletion, consumer connect/disconnect
PostgreSQL Cluster	Compliance	Query logs (DDL always; DML on sensitive tables), connection logs, authentication failures, vacuum/checkpoint events
MongoDB Cluster	Operational	Slow query log (>100 ms), authentication events, replication events
Jump Host	Security / Forensic	Full session recording (keystroke + timing logs for all administrative sessions via Teleport or similar), command history
Monitoring Server	Operational	Prometheus scrape errors, Alertmanager notification deliveries and failures
Windows Endpoints (EHV, GRN)	Security	Windows Security Event Log (logon/logoff, privilege use, process creation — Event IDs 4624, 4625, 4648, 4688, 4697)

Table 6.4: Log sources, categories and content

6.3.3. Centralised Log Architecture

All log sources forward data to a centralised log management platform running on the monitoring server in the Management VLAN. The recommended stack is:

- **Fluent Bit** (lightweight forwarder): runs as a daemon on all hosts; collects, parses and forwards logs over TLS to the central aggregator. Fluent Bit is chosen over Filebeat for its lower resource footprint (relevant on the WMS node at Groningen).
- **Loki** (log aggregation): stores logs indexed by labels (host, service, VLAN, site). Loki's label-based indexing model is highly efficient for the LogiFlux log volume and integrates natively with Grafana for unified log and metrics exploration.
- **Grafana** (log query UI): IT staff query logs using Grafana's Explore interface with LogQL, the same platform used for performance dashboards (Assignment 2). This avoids deploying a separate UI for logs.

For long-term cold storage (compliance retention beyond 30 days), Loki is configured with an **S3-compatible object storage backend** (on-premises MinIO instance or a compliant cloud bucket). This separates hot operational logs (fast SSD storage, 30-day retention) from cold compliance logs (object storage, 7-year retention for financial audit logs, 36-month retention for security logs per NFR-SEC-05).

6.3.4. Retention Policy

Log Category	Hot (fast)	Cold (object)	Legal/Policy Basis
Security logs (FW, IAM, Jump Host)	30 days	36 months	NFR-SEC-05 / GDPR / incident response
Application audit logs (Accounting)	90 days	7 years	Dutch fiscal law (Belastingdienst)
Application audit logs (HR/Payroll)	90 days	5 years	GDPR / Dutch employment law
Operational logs (web, app servers)	14 days	6 months	Internal policy
RabbitMQ / DB operational logs	14 days	3 months	Internal policy
Jump Host session recordings	90 days	24 months	Security policy / forensic readiness
Windows endpoint event logs	14 days	12 months	Security policy

Table 6.5: Log retention policy by category

6.3.5. Forensic Readiness

Forensic readiness means that the organisation can respond to a security incident or legal request without having to begin evidence collection after the fact. The following measures are implemented:

1. **Tamper-evident log shipping:** Logs are forwarded from source hosts to the central Loki instance via TLS-encrypted, authenticated channels (mTLS between Fluent Bit agents and the Loki ingestor). Once stored in object storage, logs are write-once (object lock / immutability policy) to prevent post-incident modification.
2. **Jump Host session recording:** All administrative sessions through the jump host are recorded using **Teleport** (or equivalent PAM solution), producing a timestamped, replay-capable session log. These recordings are stored in the object store under an immutable retention policy and are immediately available for investigation. This directly satisfies MR-05 and UR-05.
3. **Log integrity:** Each batch of logs shipped to the central aggregator includes an HMAC checksum, allowing verification that no log entries have been deleted or altered in transit or storage.
4. **Chain of custody documentation:** A documented procedure defines who may access log data for forensic purposes, under what conditions, and how evidence is preserved and handed over to external parties (law enforcement, auditors). This procedure is owned by the IT Director.
5. **Forensic collection triggers:** If a P1 security alert is fired, Alertmanager automatically triggers a log snapshot job that archives a 72-hour log window from all sources into a cryptographically signed ZIP archive in isolated storage. This preserves evidence even if an attacker subsequently attempts to delete log data.

6.3.6. Information Flow

The logging information flow is as follows:

1. Sources generate log events (application logs, syslog, Windows Event Log, session recordings).
2. Fluent Bit agents on each host parse, structure (JSON) and enrich events with metadata (hostname, VLAN, site, service name).
3. Events are forwarded over TLS to the Loki ingestor on the Monitoring Server.
4. Loki stores hot logs on local SSD. A background job streams logs older than the hot-tier threshold to the MinIO object store.
5. Grafana provides query access to all tiers via LogQL. Role-based access control limits which log streams each user may query.
6. Alertmanager monitors Loki for pattern-based log alerts (e.g. repeated authentication failures, firewall rule violations) and notifies IT staff via the same alert routing defined in Assignment 3.

6.3.7. GDPR Considerations

Centralised logging inevitably involves processing personal data (usernames, IP addresses, potentially employee activity records). The following GDPR-aligned controls are applied:

- Log data is **pseudonymised** where possible: internal user identifiers replace full names in non-audit logs.
- Access to logs containing personal data (HR audit logs, employee endpoint logs) is restricted to the IT Director and HR Manager by Grafana RBAC policy.
- A **Data Processing Register** entry is maintained for the logging system, documenting data categories, retention periods and access controls.
- Logs are stored **within the EU** (on-premises in the Netherlands; any cloud object storage uses an EU region).